

Roles and permissions

CareO care home management · checked against the code on 5 October 2026 (branch `tests`)

How access is enforced (three layers)

1. **Server route guard** (`middleware.ts` + `lib/route-access.ts`): signed-out users go to `/login`. Every menu page and resident section is checked against the role before it renders; a page the role may not open redirects to its home (resident sections: back to the resident). Kitchen, RQIA and MDT cannot open `/settings`.
2. **Browser checks**: menu items (`lib/permissions.ts`), page guards (`lib/route-guards.ts`), the RQIA / MDT session lock (`app/(dashboard)/layout.tsx`) and buttons hidden per role. "URL" in the tables marks a page that is allowed but has no menu link.
3. **Database rules** (Supabase RLS): the final word on what each role can read and change. A blocked write usually fails silently (0 rows), so test by checking the saved data.

Where the layers disagree, the database wins for data; the gaps are listed at the end.

1. Roles at a glance

Role	Key	Who	Scope	Created by	Lands on
Owner	<code>owner</code>	Organisation owner	Every care home in the organisation (can switch care home)	Platform admin	Home dashboard
Manager	<code>manager</code>	Care home manager	One care home (all units in it)	Owner	Home dashboard
Nurse	<code>nurse</code>	Registered nurse	One care home; lists default to their unit	Manager	Home dashboard
Care assistant	<code>care_assistant</code>	Care / support worker	One care home; lists default to their unit	Manager	Home dashboard
Agency nurse	<code>agency_nurse</code>	Agency nurse on shift	The care home that took them on	Agency onboarding (link code / request)	Home dashboard
Agency care assistant	<code>agency_care_assistant</code>	Agency carer on shift	The care home that took them on	Agency onboarding (link code / request)	Home dashboard
RQIA inspector	<code>rqia</code>	External regulator (read-only)	One care home, during an inspection session	Manager	RQIA session form, then RQIA Portal
MDT visitor	<code>mdt</code>	External professional (GP, physio, SALT...)	One resident per visit session	Manager	MDT session form, then that resident's MDT notes
Kitchen staff	<code>kitchen_staff</code>	Chef / kitchen team	One care home, diet data only	Manager	Kitchen Portal
Platform admin	<code>saas_admin</code>	CareO staff	All organisations	Another platform admin	Platform Admin (/admin)

Rank used for role changes and removals: platform admin 4 · owner 3 · manager 2 · every other role 1. You can only act on members ranked below you.

2. Navigation and pages

✓ allowed **URL** not in the menu, but the page opens by URL **view** read only **part** partly (see note) – no access

Feature	O	M	N	CA	AN	ACA	RQ	MDT	K	Notes
Main sidebar (care staff)										
Home dashboard	✓	✓	✓	✓	✓	✓	–	–	–	
Residents list	✓	✓	✓	✓	✓	✓	–	–	–	Owner: all homes; others: own home.
Add Resident button	✓	✓	✓	–	–	–	–	–	–	
Staff	✓	✓	✓	–	–	–	–	–	–	Nurse sees only the External section (RQIA/MDT accounts).
Agency	✓	✓	✓	–	–	–	–	–	–	
Staff Rota	✓	✓	✓	✓	–	–	–	–	–	Management tabs: owner, manager, approved nurse only.
Handover	✓	✓	✓	✓	✓	✓	–	–	–	
Appointment	✓	✓	✓	–	✓	–	–	–	–	
Incidents	✓	✓	✓	–	✓	–	–	–	–	
Action Plans	✓	✓	✓	✓	✓	✓	–	–	–	
Notification	✓	✓	✓	✓	✓	✓	–	–	–	
Wounds	✓	✓	✓	–	✓	–	–	–	–	
Medications (overview)	✓	✓	✓	–	✓	–	–	–	–	
Quick Info: weight / bowel / fluid checks	✓	✓	✓	✓	✓	✓	–	–	–	
Audits: Care File Audit, Manager Audit	✓	✓	–	–	–	–	–	–	–	Route guard: owner, manager.
CareO Audit (no menu link)	URL	URL	URL	–	–	–	–	–	–	Opens by URL or from audit pages.
Help and Support	✓	✓	✓	✓	✓	✓	–	–	–	
Dedicated portals										
RQIA Portal (residents, forms, incidents, wounds, weight, care, care plans, medication, audits)	–	–	–	–	–	–	✓	–	–	
MDT visit: one resident's Multidisciplinary Notes	–	–	–	–	–	–	–	✓	–	
Kitchen Portal: diet information, kitchen action plans, diet bell	–	–	–	–	–	–	–	–	✓	
Settings (/settings)										
Profile, Security (own account)	✓	✓	✓	✓	✓	✓	–	–	–	RQIA, MDT and kitchen staff are sent back to their portal.
Members list	✓	✓	✓	✓	✓	✓	–	–	–	Invite / remove: owner, manager.
Care home, Organisation pages	✓	✓	✓	✓	✓	✓	–	–	–	Edit buttons work for the owner only (UI).

3. Resident profile sections

Which resident sections each role sees in the resident menu. RQIA open them from the RQIA Portal; MDT only for the visit's resident.

✓ allowed **URL** not in the menu, but the page opens by URL **view** read only **part** partly (see note) – no access

Feature	O	M	N	CA	AN	ACA	RQ	MDT	K	Notes
Resident profile sections (view)										
Overview	✓	✓	✓	✓	✓	✓	–	–	–	Edit: owner, manager, nurse (agency nurse sees edit but the save is refused, see Gaps).
Care File (assessments, care plans, risk assessments)	✓	✓	✓	view	✓	view	–	–	–	Same roles fill in the forms. Care assistants can browse folders read-only (no card on the profile; reached from Overview tasks).
Medication	✓	✓	✓	–	✓	–	–	–	–	
Topical Medication (creams)	✓	✓	✓	✓	✓	✓	–	–	–	The profile shows this card to care assistants.
Food & Fluid	✓	✓	✓	✓	✓	✓	–	–	–	Diet / menu changes: owner, manager, nurse, agency nurse.
Daily Care	✓	✓	✓	✓	✓	✓	–	–	–	Quick care notes: owner, manager, nurse, agency nurse.
Continence	✓	✓	✓	✓	✓	✓	–	–	–	
Lifestyle & Social	✓	✓	✓	✓	✓	✓	–	–	–	
Progress Notes	✓	✓	✓	–	✓	–	–	–	–	
Documents	✓	✓	✓	–	✓	–	–	–	–	
Checks (night checks etc.)	✓	✓	✓	✓	✓	✓	view	–	–	Add / delete night checks: owner, manager, nurse, agency nurse.
Appointments	✓	✓	✓	–	✓	–	–	–	–	
Incidents & Falls	✓	✓	✓	–	✓	–	view	–	–	
Health & Monitoring (vitals, weight)	✓	✓	✓	–	✓	–	–	–	–	
Weight monitoring	✓	✓	✓	✓	✓	✓	–	–	–	Care assistants reach it from Quick Info > Weight Check.
Clinical, Wounds	✓	✓	✓	–	✓	–	view	–	–	
Hospital Transfer (passport, transfer log)	✓	✓	✓	–	✓	–	–	–	–	
Multidisciplinary Notes	✓	✓	✓	–	✓	–	–	part	–	MDT: only the resident chosen for the visit.

4. Actions

✓ allowed **URL** not in the menu, but the page opens by URL **view** read only **part** partly (see note) – no access

Feature	O	M	N	CA	AN	ACA	RQ	MDT	K	Notes
Residents										
Create a resident	✓	✓	✓	–	–	–	–	–	–	
Edit / delete a resident	✓	✓	✓	–	–	–	–	–	–	Enforced in the database.
Switch care home	✓	–	–	–	–	–	–	–	–	Everyone else is fixed to their care home.

Feature	O	M	N	CA	AN	ACA	RQ	MDT	K	Notes
Switch unit (team) inside own care home	✓	✓	✓	✓	✓	✓	–	–	–	
Medication										
Add a medication	✓	✓	✓	–	✓	–	–	–	–	Needs a 'Checked by' colleague: any organisation account except yourself (owner included).
Prepare / administer / record outcome (round, PRN, topical, eMAR)	✓	✓	✓	–	✓	–	–	–	–	
Be chosen as a witness	–	✓	✓	✓	✓	✓	part	part	part	List = every account in the organisation except you and the owner, so RQIA, MDT, kitchen and other care homes' staff also appear (see Gaps).
Complete a medication round	✓	✓	✓	–	✓	–	–	–	–	
Care records										
Log food & fluid, daily care, continence, activities	✓	✓	✓	✓	✓	✓	–	–	–	
Write progress notes	✓	✓	✓	–	✓	–	–	–	–	Always saved under your own name.
Record vitals and weight	✓	✓	✓	–	✓	–	–	–	–	
Create wounds, incidents, hospital passports, appointments	✓	✓	✓	–	✓	–	–	–	–	
Write MDT notes	✓	✓	✓	–	✓	–	–	part	–	MDT: their session's resident only.
Upload resident documents	✓	✓	✓	–	✓	–	–	–	–	
Handover and action plans										
Write handover notes, Save Handover	✓	✓	✓	✓	✓	✓	–	–	–	
Create a care home action plan	✓	✓	✓	✓	✓	✓	–	–	–	Assignee must be in the same care home; never the owner.
Update an action plan's status	✓	✓	✓	✓	✓	✓	–	–	part	Assignee or creator; managers see all in their home, owner all in the organisation. Kitchen: kitchen plans.
Create and complete CareO / Manager audits	✓	✓	part	–	–	–	–	–	–	Manager Audit: owner, manager. CareO Audit: owner, manager, nurse.
Staff and workforce										
Invite staff	✓	✓	–	–	–	–	–	–	–	Owner → manager. Manager → nurse, care assistant, MDT, RQIA, kitchen staff.
Remove a member	✓	✓	–	–	–	–	–	–	–	Only lower-ranked members; not yourself; never the owner.
Change a member's role	✓	✓	–	–	–	–	–	–	–	Only to a role below your own.
Open a staff profile / trainings	✓	✓	–	–	–	–	–	–	–	
Add staff training records	✓	✓	–	–	–	–	–	–	–	Staff can read their own records.
Set contracted hours, approve 'manager approved nurse'	✓	✓	–	–	–	–	–	–	–	
Turn RQIA / MDT logins on or off	✓	✓	✓	–	–	–	–	–	–	
Build / publish rotas, shift templates, staffing rules, leave	✓	✓	part	–	–	–	–	–	–	Nurse only when approved by a manager, for their own unit.

Feature	O	M	N	CA	AN	ACA	RQ	MDT	K	Notes
Request leave, request / answer shift swaps	✓	✓	✓	✓	–	–	–	–	–	
Generate agency link code, approve agency requests	✓	✓	✓	–	–	–	–	–	–	
Organisation settings										
Rename care home	✓	part	–	–	–	–	–	–	–	UI: owner only. Database also lets managers (open item D13).
Edit organisation details	✓	part	–	–	–	–	–	–	–	UI: owner only. Database also lets managers.
Create / edit units (teams)	✓	✓	–	–	–	–	–	–	–	
Create / edit labels	✓	✓	✓	✓	✓	✓	–	–	–	No UI restriction.

5. Each role: can / cannot

Owner (owner)

Can

- Everything a manager can do, in every care home of the organisation (switch care home from the sidebar).
- Invite managers; remove managers and lower roles.
- Edit organisation and care home details (Settings).
- See all action plans in the organisation; open Manager Audit and Care File Audit.
- Manage rotas for any unit in the organisation.

Cannot

- Be chosen as a medication witness or assigned a care home action plan.
- Be removed or demoted by anyone in the organisation.

Manager (manager)

Can

- Full clinical access to every resident in their care home (all sections, all actions in the matrices).
- Create / edit residents; manage units (teams).
- Invite nurses, care assistants, MDT, RQIA and kitchen staff; remove lower-ranked members; change their roles.
- Staff page: contracted hours, approve nurses for rota management, turn RQIA/MDT logins on/off, staff profiles and training records.
- Rota Builder, Shift Templates, Staffing Requirements, Leave Management, Audit Trail.
- Manager Audit, Care File Audit, CareO Audit; all action plans of the care home.
- Agency page: link code, agency requests.

Cannot

- See or change another care home's data (even in the same organisation).
- Invite or promote anyone to manager or owner; remove the owner.
- Edit organisation / care home settings in the UI (database allows it, see Gaps).

Nurse (nurse)

Can

- All resident sections; create and edit residents.
- Medication: add (with a second checker), prepare, administer, witness for others, complete rounds.
- Care file forms, progress notes, vitals, wounds, incidents, hospital passports, appointments, documents, MDT notes.
- Handover, action plans, Quick Info checks.
- Staff page (External section only): turn RQIA/MDT logins on/off.
- Agency page; Rota (view own shifts, leave, swaps). Manage the rota of their unit if a manager approved them.
- CareO Audit by URL.

Cannot

- Invite or remove members; see permanent staff on the Staff page; open staff profiles / trainings.
- Open Manager Audit or Care File Audit.
- Switch care home; witness their own medication dose.

Care assistant (care_assistant)

Can

- View residents of their care home: Overview, Food & Fluid, Daily Care, Continence, Lifestyle & Social, Checks, Topical Medication, Weight monitoring; browse Care File folders read-only.
- Log food & fluid, daily care, continence, activities.
- Handover notes, action plans (create / update own), notifications, Quick Info checks.
- Rota: view own shifts, request leave and swaps.
- Be chosen as a medication witness.

Cannot

- Open Medication, Care File, Progress Notes, Documents, Appointments, Incidents, Health & Monitoring, Clinical, Wounds, Hospital Transfer or MDT notes in the resident profile.
- Create or edit residents.
- Open Staff, Audits, staff profiles; invite or remove anyone.
- Open Medications, Incidents, Appointment, Agency or Wounds, even by URL (redirected to Home).

Agency nurse (agency_nurse)

Can

- Same resident and clinical access as a nurse (all sections, medication, incidents, care file...).
- Handover, Appointment, Incidents, Action Plans, Notification, Wounds, Medications, Quick Info.

Cannot

- Create or edit residents (UI shows edit on Overview, but the save is refused).
- Staff, Agency, Rota, Audits, Add Resident (redirected to Home, even by URL).
- Invite, remove or manage anyone.

Agency care assistant (agency_care_assistant)

Can

- Same as a care assistant: daily care, food & fluid, continence, activities, handover, action plans, Quick Info.

Cannot

- Everything a care assistant cannot do, plus the Rota (not in their menu).

RQIA inspector (rqia)

Can

- Start an inspection session (inspector name) and use the RQIA Portal for their care home.
- Read residents, forms, incidents and falls, wounds, weight, care records, care plans, medication and audits; download stored files.
- Open resident pages under /dashboard/residents/...

Cannot

- Create or change any record (database: read-only; only their own login log is written).
- Open any other dashboard page or /settings (redirected to the RQIA Portal).
- Use the app at all once a manager or nurse turns their login off.

MDT visitor (mdt)

Can

- Start a visit session for one resident and write that resident's Multidisciplinary Notes (care team, attached files).
- Change resident by starting a new session.

Cannot

- Open any other page or /settings (redirected to the chosen resident's MDT notes).
- Change any record except MDT notes, the MDT care team, and their files / folders.
- Use the app once their login is turned off.

Kitchen staff (kitchen_staff)

Can

- Kitchen Portal: resident diet information, diet-change bell (mark read), kitchen action plans (create, update status).

Cannot

- Open any other /dashboard page or /settings (blocked on the server, including via Back).
- Read clinical records (medication, notes, DNACPR, incidents...), enforced in the database.

Platform admin (saas_admin)

Can

- Platform Admin: owners (create, list), care homes per organisation, agencies, other platform admins, analytics.
- Invite owners and managers; bypasses organisation and care home scoping in the database.

Cannot

- Use the care-home dashboard (redirected to /admin). Route guards that list admin do not match saas_admin.

6. Database rules (apply whatever the UI shows)

- **Care home scope.** Every data table is limited to the user's active care home; owners reach every home in their organisation; platform admins reach everything.
- **Care staff** (owner, manager, nurse, care assistant, agency nurse, agency care assistant) may write care records in their home. The database does **not** separate nurses from care assistants: that split is only in the UI.
- **RQIA** read everything in their care home and write nothing (except their own login log). **MDT** read in their care home and write only MDT notes, the MDT care team, files and folders. Both lose all access when their login is turned off.
- **Kitchen staff** read and write only diet data, menus, food & fluid logs, notifications and audit action plans. Clinical tables are hidden.
- **Residents:** create / edit / delete by owner, manager, nurse. Everyone in scope can read.
- **Users:** nobody can change their own role, organisation, care home, approved-nurse flag or workforce fields. Owners / managers can change other staff only to a role below their own and cannot move them to another organisation.
- **Rota:** managed by owner (organisation), manager (care home), approved nurse (own unit). Everyone else sees rotas of their unit and their own shifts.
- **Invitations:** owner → manager, nurse, care assistant, MDT, RQIA, kitchen; manager → nurse, care assistant, MDT, RQIA, kitchen (own care home); platform admin → owner, manager.
- **Staff training records:** read by the staff member and by owners / managers of their care home; written by owners / managers only.

7. Known gaps and inconsistencies (to test or fix)

- **Agency nurse resident edit:** the Overview shows edit controls (`canEditOverview`), but the database refuses the update (0 rows, no error shown).
- **UI vs database:** managers can rename the care home, edit the organisation and create care homes in the database although the UI is owner-only (D13). Labels and teams have no UI restriction; teams are refused by the database for non-managers.
- **RQIA / MDT session lock is browser-side** (session cookie in the dashboard layout): the server guard limits them to their sections, but which resident an MDT visitor may open is only checked in the browser. The database still limits them to read-only / MDT-only.
- **Invite UI is narrower than the database:** the owner's invite dialog offers only `manager` ; the database would also accept nurse, care assistant, MDT, RQIA and kitchen.
- **Medication witness and 'Checked by' lists** are built from every account whose active organisation matches: they include RQIA, MDT and kitchen accounts and staff of other care homes in the organisation. Only you (both lists) and the owner (witness list) are excluded.

8. Testing the roles

- Run any Playwright spec (e.g. `npx playwright test tests/e2e/journeys.spec.ts`) to create fixture organisations A and B, care homes A1, A2, B1 and one user per role in A1 (owner, manager, nurse, care_assistant, agency_nurse, mdt, rqia, kitchen_staff), plus A2 nurse/manager and B1 owner/nurse/mdt/rqia.
- Emails are in `tests/e2e/.auth/world.json` ; password for all: `Test-Password-123!` .
- RQIA and MDT accounts must complete their session form (inspector name / resident) before any other page opens.
- Role checks with automated coverage: `tests/e2e/journeys.spec.ts` (navigation), `tests/e2e/page-sweep.spec.ts` (every page per role), `tests/db/role-scope.test.ts` , `tests/db/tenant-isolation.test.ts` , `tests/db/privilege-escalation.test.ts` .

Source files: `lib/permissions.ts` , `lib/route-guards.ts` , `middleware.ts` , `app/(dashboard)/layout.tsx` , `components/navigation/AppSidebar.tsx` , `supabase/migrations/20261005120000_security_hardening.sql` and later migrations. Regenerate with `node docs/roles/render.mjs` after permission changes.